

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

«Технология сертификации средств защиты информации»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №3

«Моделирование угроз»

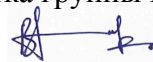
Выполнили:

Чу Ван Доан, студент группы N3447



(подпись)

Чан Бао Линь, студентка группы N3446



(подпись)

Доан Тхи Хоай Тхыонг, студентка группы N3445



(подпись)

Проверил:

Бегаев Алексей Николаевич, к.т.н. ФБИТ

(отметка о выполнении)

(подпись)

Санкт-Петербург

2026 г.

СОДЕРЖАНИЕ

Содержание.....	2
Введение.....	3
1 Ход работы.....	4
1.1 Теоретическое неформальное описание системы/ПО.....	4
1.2 Описание субъектов, объектов, активов, процессов.....	4
1.3 Диаграмма потоков данных.....	8
1.4 Моделирование угроз.....	11
1.5 Диаграмма с угрозами.....	13
1.6 Перечень угроз.....	14
1.7 Диаграмма с контрмерами.....	15
1.8 Описание контрмер и таблица соответствий «угроза–противодействие».....	17
Заключение.....	21

ВВЕДЕНИЕ

Цель работы: построение модели угроз для SIEM-системы, выявление основных угроз информационной безопасности и определение контрмер для их снижения.

Для достижения поставленной цели необходимо выполнить следующие задачи:

1. выполнить теоретическое неформальное описание системы/ПО;
2. описать субъектов, объекты, активы, процессы и другие элементы системы;
3. построить диаграмму потоков данных;
4. выполнить моделирование угроз;
5. построить диаграмму с угрозами;
6. составить перечень угроз;
7. построить диаграмму с контрмерами;
8. описать контрмеры и составить таблицу соответствий «угроза–противодействие».

Вариант 15 - SIEM-система

1.1 Теоретическое неформальное описание системы/ПО

SIEM (Security Information and Event Management) — это система обеспечения информационной безопасности, предназначенная для централизованного сбора, хранения, анализа и корреляции событий безопасности, поступающих из различных источников инфраструктуры организации. К таким источникам относятся серверы, рабочие станции, сетевые устройства, межсетевые экраны, системы обнаружения вторжений, средства защиты конечных точек и прикладные сервисы.

Основной целью SIEM-системы является своевременное обнаружение инцидентов информационной безопасности, выявление аномальной активности, корреляция связанных событий и оповещение операторов о возможных угрозах. SIEM-система позволяет повысить осведомленность о состоянии защищенности инфраструктуры, сократить время обнаружения инцидентов и упростить расследование произошедших событий.

К основным функциям SIEM-системы относятся:

- сбор логов и событий из различных источников;
- нормализация и агрегация поступающих данных;
- корреляция событий по заданным правилам;
- выявление аномалий и потенциальных атак;
- формирование оповещений;
- хранение журналов событий;
- предоставление интерфейса операторам и администраторам для мониторинга и реагирования.

Таким образом, SIEM-система является критически важным элементом инфраструктуры информационной безопасности организации, поскольку обрабатывает значительный объем служебной информации, журналов безопасности и данных о событиях, от которых зависит своевременное реагирование на инциденты.

1.2 Описание субъектов, объектов, активов, процессов

Для построения модели угроз SIEM-системы необходимо определить основные элементы системы, а именно субъектов, объекты защиты, активы и ключевые процессы. Это позволяет установить, какие компоненты участвуют в обработке информации, какие данные имеют наибольшую ценность и какие процессы являются критичными с точки зрения информационной безопасности.

Таблица 1 – Субъекты SIEM-системы

№	Субъект	Роль в системе	Права и возможности
1	Оператор SIEM-системы	Осуществляет мониторинг событий безопасности, анализирует оповещения и реагирует на инциденты	Просмотр журналов событий, оповещений, отчетов, запуск процедур реагирования
2	Администратор SIEM-системы	Выполняет настройку, сопровождение и администрирование системы	Управление конфигурацией, учетными записями, правилами корреляции, источниками событий
3	Источники событий	Передают журналы и события безопасности в SIEM-систему	Формирование и отправка логов, событий и уведомлений
4	Система хранения данных	Обеспечивает хранение журналов, конфигурации и результатов анализа	Сохранение, чтение, архивирование и удаление данных
5	Внешний нарушитель	Пытается получить несанкционированный доступ к системе извне	Подмена источников, атаки на интерфейсы, перехват трафика, DoS-атаки
6	Внутренний нарушитель	Обладает определенным уровнем легитимного доступа и может злоупотреблять им	Несанкционированное изменение конфигурации, просмотр логов, удаление данных, повышение привилегий

Таблица 2 – Объекты защиты SIEM-системы

№	Объект	Назначение	Обрабатываемая информация
1	Сервер SIEM	Центральный узел обработки и управления системой	События ИБ, служебные данные, результаты корреляции
2	Веб-интерфейс SIEM	Предоставляет доступ оператору и администратору к функциям системы	Учетные данные, оповещения, отчеты, настройки
3	Модуль сбора событий	Принимает логи и события от внешних источников	Журналы безопасности, системные события, сетевые события
4	Модуль корреляции и анализа	Обрабатывает события и выявляет инциденты	Нормализованные события, правила корреляции, сигнатуры

5	Хранилище событий ИБ	Сохраняет поступающие события и результаты обработки	Логи, архивы, метаданные, история инцидентов
6	Хранилище конфигурации	Содержит параметры работы системы и правила корреляции	Настройки SIEM, политики, учетные записи, роли
7	Каналы передачи данных	Обеспечивают обмен данными между источниками и SIEM-системой	Передаваемые логи, команды управления, служебный трафик
8	Рабочее место оператора	Используется для наблюдения за состоянием ИБ и реагирования	Оповещения, отчеты, карточки инцидентов
9	Рабочее место администратора	Используется для настройки и сопровождения системы	Параметры системы, учетные записи, конфигурационные данные

Таблица 3 – Активы SIEM-системы

№	Актив	Ценность актива	Свойства безопасности
1	Журналы событий безопасности	Используются для обнаружения, анализа и расследования инцидентов	Конфиденциальность, целостность, доступность
2	Правила корреляции	Определяют логику выявления инцидентов и аномалий	Целостность, доступность
3	Конфигурация SIEM-системы	Влияет на корректность функционирования всей системы	Целостность, доступность
4	Учетные записи пользователей	Обеспечивают доступ к функциям SIEM-системы	Конфиденциальность, целостность
5	Оповещения о событиях ИБ	Позволяют своевременно реагировать на угрозы	Целостность, доступность
6	Архив событий	Необходим для хранения истории и последующего расследования	Конфиденциальность, целостность, доступность
7	Сведения о защищаемой инфраструктуре	Содержат информацию о структуре сети и источниках событий	Конфиденциальность

8	Доступность SIEM-системы	Критична для непрерывного мониторинга безопасности	Доступность
9	Репутация организации	Может пострадать при компрометации SIEM-системы	Косвенно зависит от всех свойств ИБ

Таблица 4 – Основные процессы SIEM-системы

№	Процесс	Входные данные	Выходные данные	Участники
1	Сбор событий	Логи и события от серверов, сетевых устройств, приложений	Принятые сырые события	Источники событий, модуль сбора
2	Передача событий	Сырые события, служебные сообщения	Поток данных в SIEM-систему	Источники событий, каналы связи
3	Нормализация данных	Сырые события различных форматов	Приведенные к единому формату события	Модуль сбора, модуль анализа
4	Корреляция событий	Нормализованные события, правила корреляции	Выявленные связи между событиями, инциденты	Модуль анализа
5	Формирование оповещений	Результаты корреляции и обнаруженные аномалии	Уведомления оператору, отчеты, карточки инцидентов	Модуль анализа, оператор
6	Хранение журналов	Принятые и обработанные события	Записи в хранилище событий	Хранилище событий
7	Администрирование системы	Команды администратора, параметры настройки	Обновленная конфигурация, измененные правила	Администратор, SIEM-сервер
8	Архивирование и удаление данных	Устаревшие журналы и архивы	Освобожденное пространство, архивы событий	Администратор, хранилище данных

9	Реагирование на инциденты	Оповещения, отчеты, данные расследования	Принятые меры реагирования, закрытие инцидента	Оператор, администратор
---	---------------------------	--	--	-------------------------

Таким образом, в рамках анализа были определены основные субъекты SIEM-системы, выделены объекты защиты, установлены ключевые активы и рассмотрены основные процессы обработки и хранения событий безопасности. Полученные результаты служат основой для дальнейшего построения диаграммы потоков данных и моделирования угроз.

1.3 Диаграмма потоков данных

Диаграмма потоков данных SIEM-системы отражает основные сущности, процессы обработки информации, хранилища данных и направления передачи информации между ними. В рассматриваемой модели внешними сущностями являются пользователь, аналитик и оператор, а также источники событий, формирующие данные о состоянии информационной системы. Основными внутренними компонентами являются подсистема сбора событий, хранилище событий информационной безопасности, подсистема аналитики и подсистема мониторинга. В качестве защищаемых активов в диаграмме выделяются журналы событий и учетные данные пользователей.

Поток данных в SIEM-системе начинается с источников событий, к которым относятся серверы, сетевые устройства, межсетевые экраны, приложения и иные элементы инфраструктуры. Эти компоненты формируют журналы и события безопасности и передают их в подсистему сбора событий. Передача может осуществляться как агентным способом, так и по стандартным протоколам, например Syslog. На данном этапе происходит прием исходных журналов и их первичная доставка в систему централизованного анализа.

После поступления данных в подсистему сбора событий выполняется их предварительная обработка: фильтрация, разбор, нормализация и приведение к единому формату. Это необходимо для того, чтобы события, поступающие из разных источников и имеющие различную структуру, могли быть корректно сопоставлены и обработаны в рамках единой SIEM-системы. Затем нормализованные данные передаются в хранилище событий ИБ, где сохраняются для последующего анализа, поиска, расследования инцидентов и аудита.

Следующим этапом является передача накопленных и нормализованных данных в подсистему аналитики. В этой подсистеме выполняется корреляция событий, поиск

взаимосвязей между ними, выявление аномалий и определение признаков потенциальных инцидентов информационной безопасности. Если в ходе анализа обнаруживаются подозрительные закономерности или нарушения, система формирует результаты анализа и передает их в подсистему мониторинга.

Подсистема мониторинга предназначена для отображения состояния безопасности, формирования уведомлений и передачи оповещений оператору. Оператор получает сведения об инцидентах, нарушениях и аномалиях, после чего может инициировать меры реагирования. Аналитик, в свою очередь, взаимодействует с подсистемой аналитики, используя сохраненные и обработанные события для более глубокого расследования, оценки причин инцидента и определения масштаба угрозы.

Таким образом, общий поток данных в SIEM-системе можно представить в следующем виде: источники событий -> подсистема сбора событий -> хранилище событий ИБ -> подсистема аналитики -> подсистема мониторинга -> оператор, при этом аналитик получает доступ к результатам анализа и журналам событий для проведения расследования. Такая схема отражает централизованный характер работы SIEM-системы и показывает, каким образом данные проходят путь от момента генерации события до формирования предупреждения о возможном инциденте.

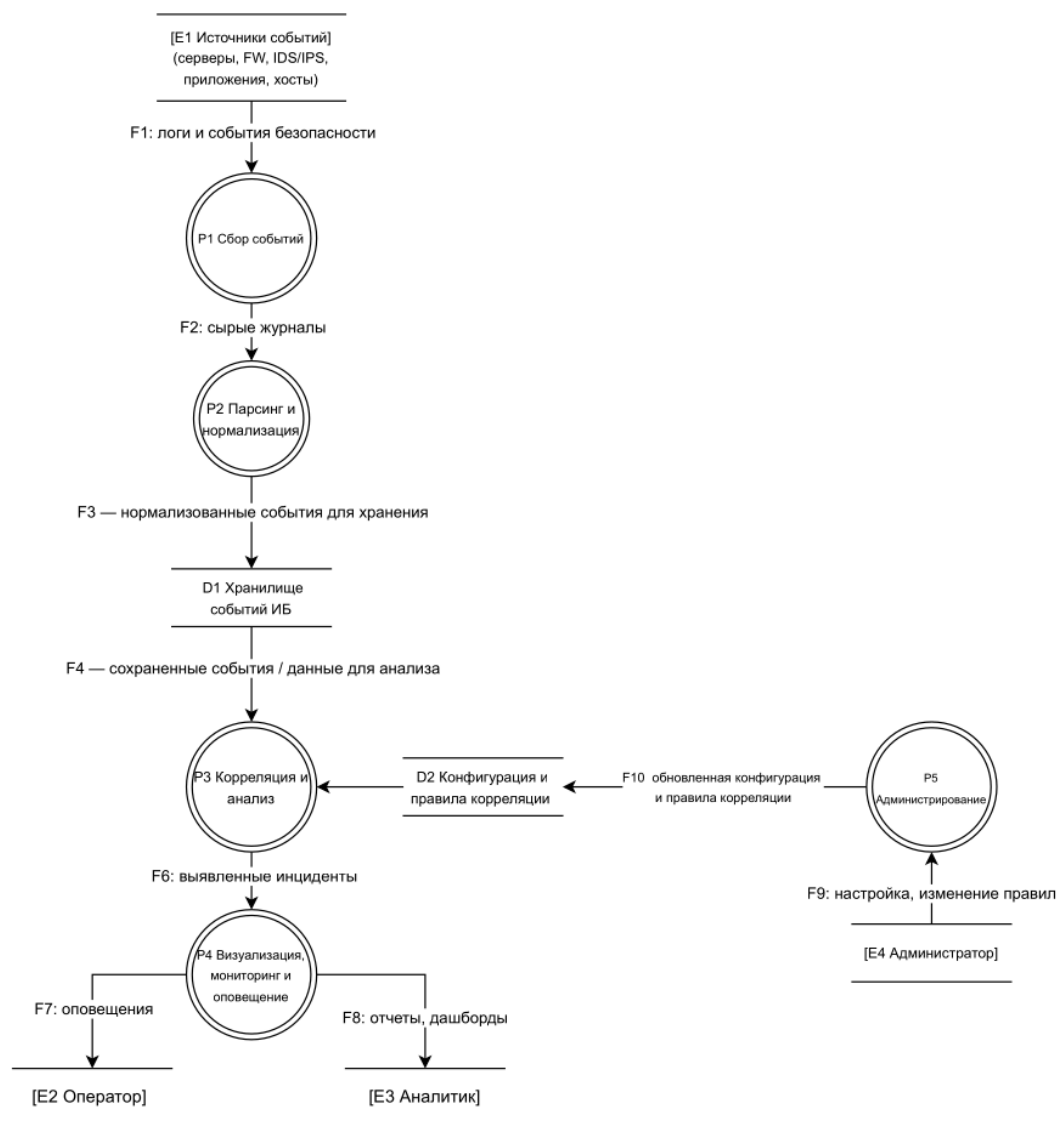


Рисунок 1 – Диаграмма потоков данных SIEM-системы

На рисунке представлена диаграмма потоков данных SIEM-системы, отражающая основные внешние сущности, процессы обработки информации, хранилища данных и связи между ними. В качестве внешней сущности E1 выступают источники событий, к которым относятся серверы, межсетевые экраны, системы IDS/IPS, приложения и рабочие станции. От указанных источников в систему поступает поток F1, содержащий журналы и события безопасности.

На первом этапе обработки данные поступают в процесс P1 «Сбор событий», где осуществляется централизованный прием логов от различных компонентов инфраструктуры. Далее по потоку F2 сырые журналы передаются в процесс P2 «Парсинг и нормализация», в котором выполняется разбор поступивших записей, приведение их к единому формату и подготовка к дальнейшему анализу.

После нормализации данные по потоку F3 поступают в хранилище D1 «Хранилище событий ИБ», предназначенное для длительного хранения журналов безопасности и их последующего использования в аналитических целях. Из данного хранилища по потоку F4 сохраненные события и данные для анализа передаются в процесс P3 «Корреляция и анализ», где выполняется выявление взаимосвязей между событиями, обнаружение аномалий и формирование сведений о возможных инцидентах информационной безопасности.

Для корректной работы механизма анализа используется хранилище D2 «Конфигурация и правила корреляции», содержащее настройки системы и правила обработки событий. Наполнение и изменение данного хранилища осуществляется через процесс P5 «Администрирование», с которым взаимодействует внешняя сущность E4 «Администратор». По потоку F9 администратор передает команды на настройку и изменение правил, а по потоку F10 обновленная конфигурация и правила корреляции поступают в хранилище D2 и далее используются процессом P3.

Результаты анализа по потоку F6 передаются в процесс P4 «Визуализация, мониторинг и оповещение», который обеспечивает отображение состояния безопасности системы, формирование уведомлений и предоставление аналитической информации пользователям. По потоку F7 оператору системы (E2) направляются оповещения о выявленных инцидентах, а по потоку F8 аналитику (E3) предоставляются отчеты и дашборды, необходимые для расследования событий и оценки текущего состояния защищенности инфраструктуры.

Таким образом, построенная диаграмма потоков данных отражает полный цикл обработки информации в SIEM-системе: от получения журналов безопасности из различных источников до их нормализации, хранения, корреляционного анализа и представления результатов операторам и аналитикам. Данная диаграмма служит основой для дальнейшего моделирования угроз и определения контрмер.

1.4 Моделирование угроз

Таблица 5 – Моделирование угроз SIEM-системы по методологии STRIDE

Категория STRIDE	Элемент DFD	Идентификатор угрозы	Описание угрозы	Возможные последствия
Spoofing	E1 Источники событий	Y01	Подмена источника событий, имитация легитимного узла инфраструктуры	Поступление недостоверных данных в SIEM-систему

Spoofing	F1, F2 Потоки логов и событий	Y02	Подделка журналов и событий безопасности	Искажение картины инцидентов, ложные срабатывания
Tampering	F1–F4 Потоки данных	Y03	Фальсификация данных при передаче по сети	Нарушение целостности журналов и результатов анализа
Tampering	D1 Хранилище событий ИБ	Y04	Несанкционированное изменение записей журналов	Соккрытие следов атаки, искажение истории событий
Tampering	D2 Конфигурация и правила корреляции	Y05	Изменение конфигурации и правил корреляции без разрешения	Некорректное обнаружение инцидентов, отключение правил
Information Disclosure	D1 Хранилище событий ИБ, F4, F8	Y06	Раскрытие журналов событий и служебной информации	Утечка сведений о структуре инфраструктуры и инцидентах
Denial of Service	F1, F2, F3 Сетевые потоки	Y07	Отказ в обслуживании на сетевом уровне	Потеря или задержка поступления событий в систему
Denial of Service	P1, P2, P3, P4	Y08	Отказ в обслуживании на уровне приложений и сервисов	Недоступность аналитики, мониторинга и оповещения
Denial of Service	D1 Хранилище событий ИБ	Y09	Переполнение журналов и исчерпание дискового пространства	Снижение производительности, остановка сохранения событий
Elevation of Privilege	E2, E3, E4, P5	Y10	Социальная инженерия и фишинг для получения повышенных прав	Несанкционированный доступ к управлению системой
Elevation of Privilege	P3, P4, P5	Y11	Эксплуатация уязвимостей приложений и сервисов SIEM-системы	Повышение привилегий, изменение конфигурации, скрытие действий

Как видно из таблицы, наиболее значимыми для SIEM-системы являются угрозы, связанные с подменой источников событий, фальсификацией журналов, раскрытием логов, отказом в обслуживании и получением повышенных привилегий. Выявленные угрозы будут использованы далее при построении диаграммы угроз и формировании перечня контрмер.

1.5 Диаграмма с угрозами

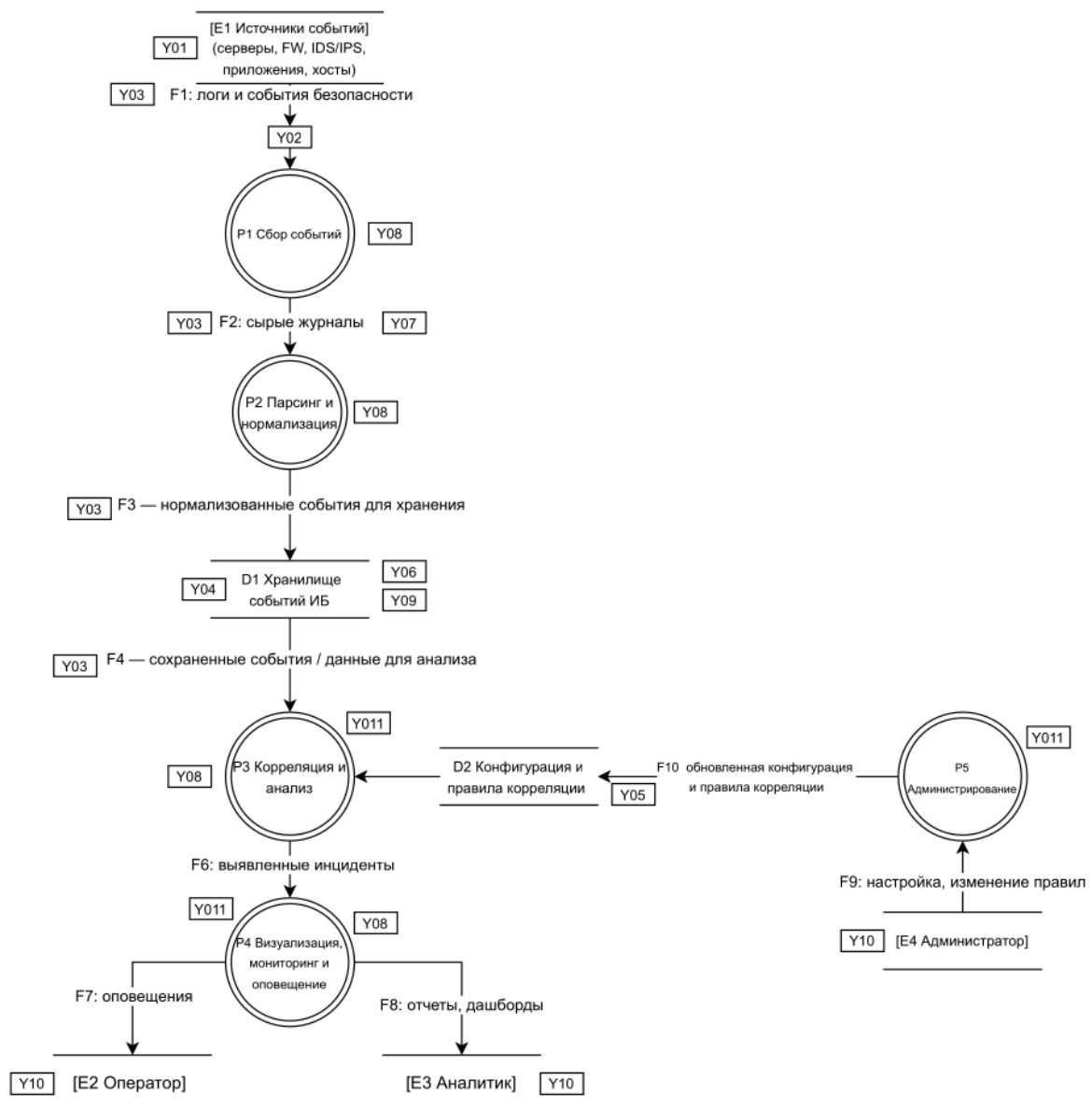


Рисунок 2 – Диаграмма угроза

На основе ранее построенной диаграммы потоков данных была разработана диаграмма с угрозами для SIEM-системы. Для этого на элементы DFD-диаграммы были нанесены идентификаторы угроз, отражающие потенциальные сценарии нарушения безопасности, характерные для рассматриваемой системы.

На диаграмме с угрозами показано, какие угрозы относятся к внешним сущностям, потокам данных, процессам обработки информации и хранилищам данных. Такой подход позволяет наглядно определить наиболее уязвимые элементы SIEM-системы и установить, на каких этапах обработки событий информационной безопасности возможно нарушение конфиденциальности, целостности и доступности данных.

В частности, для внешних источников событий были отмечены угрозы подмены источника и подделки передаваемых журналов. Для потоков данных были рассмотрены угрозы фальсификации информации при передаче и отказа в обслуживании на сетевом уровне. Для хранилища событий ИБ выделены угрозы несанкционированного изменения журналов, раскрытия служебной информации и переполнения хранилища. Для процессов корреляции, визуализации и администрирования были определены угрозы отказа в обслуживании, эксплуатации уязвимостей приложений и несанкционированного изменения конфигурации и правил корреляции. Кроме того, для пользователей системы были отмечены угрозы социальной инженерии и фишинга.

Таким образом, построенная диаграмма с угрозами позволяет наглядно представить распределение угроз по основным элементам SIEM-системы и служит основой для дальнейшего составления перечня угроз и выбора соответствующих контрмер.

1.6 Перечень угроз

Таблица 6 – Перечень угроз SIEM-системы

Идентификатор угрозы	Категория STRIDE	Наименование угрозы	Элемент DFD	Краткое описание
Y01	Spoofing	Подмена источника событий	E1	Нарушитель имитирует легитимный источник логов и событий
Y02	Spoofing	Подделка журналов и событий	F1, F2	В систему передаются ложные или сфальсифицированные журналы
Y03	Tampering	Фальсификация данных при передаче по сети	F1–F4	Данные изменяются в процессе передачи между компонентами SIEM

Y04	Tampering	Несанкционированное изменение записей журналов	D1	Изменение или удаление сохраненных событий в хранилище
Y05	Tampering	Несанкционированное изменение конфигурации и правил корреляции	D2, P5	Изменение настроек системы и правил обработки событий
Y06	Information Disclosure	Раскрытие журналов и служебной информации	D1, F8	Утечка логов, отчетов, аналитических данных и служебной информации
Y07	Denial of Service	Отказ в обслуживании на сетевом уровне	F1–F3	Перегрузка каналов передачи событий и нарушение доставки логов
Y08	Denial of Service	Отказ в обслуживании на уровне приложений	P1, P2, P3, P4	Перегрузка или вывод из строя процессов обработки и анализа
Y09	Denial of Service	Переполнение журналов	D1	Переполнение хранилища событий и исчерпание дискового пространства
Y10	Elevation of Privilege	Социальная инженерия и фишинг	E2, E3, E4, P5	Получение злоумышленником доступа к привилегированным учетным записям
Y11	Elevation of Privilege	Эксплуатация уязвимостей приложений и сервисов	P3, P4, P5	Получение повышенных прав через уязвимости SIEM-компонентов

1.7 Диаграмма с контрмерами

На основе ранее построенной диаграммы потоков данных была разработана диаграмма с контрмерами для SIEM-системы. Для этого на элементы DFD-диаграммы были нанесены идентификаторы контрмер, соответствующие техническим и организационным мерам защиты, направленным на снижение вероятности реализации выявленных угроз.

На диаграмме с контрмерами показано, какие меры защиты применяются к внешним сущностям, потокам данных, процессам обработки информации и хранилищам данных. Такой подход позволяет наглядно определить, на каких участках SIEM-системы реализуются механизмы аутентификации, контроля целостности, защищенной передачи данных, разграничения доступа, защиты от отказа в обслуживании, резервирования журналов и защиты учетных записей пользователей.

Для источников событий и потоков передачи данных предусмотрены меры проверки доверенных источников, контроля входных данных и использования защищенных каналов связи. Для хранилища событий ИБ и хранилища конфигурации определены меры разграничения доступа, резервирования и защиты критически важной информации. Для процессов корреляции, визуализации и администрирования предусмотрены меры защиты приложений и сервисов, а также механизмы ограничения нагрузки. Для пользователей системы дополнительно предусмотрены организационные меры, направленные на снижение риска компрометации учетных записей и реализации атак социальной инженерии.

Таким образом, диаграмма с контрмерами позволяет наглядно представить распределение защитных мер по основным элементам SIEM-системы и служит основой для последующего составления таблицы соответствий «угроза–противодействие».

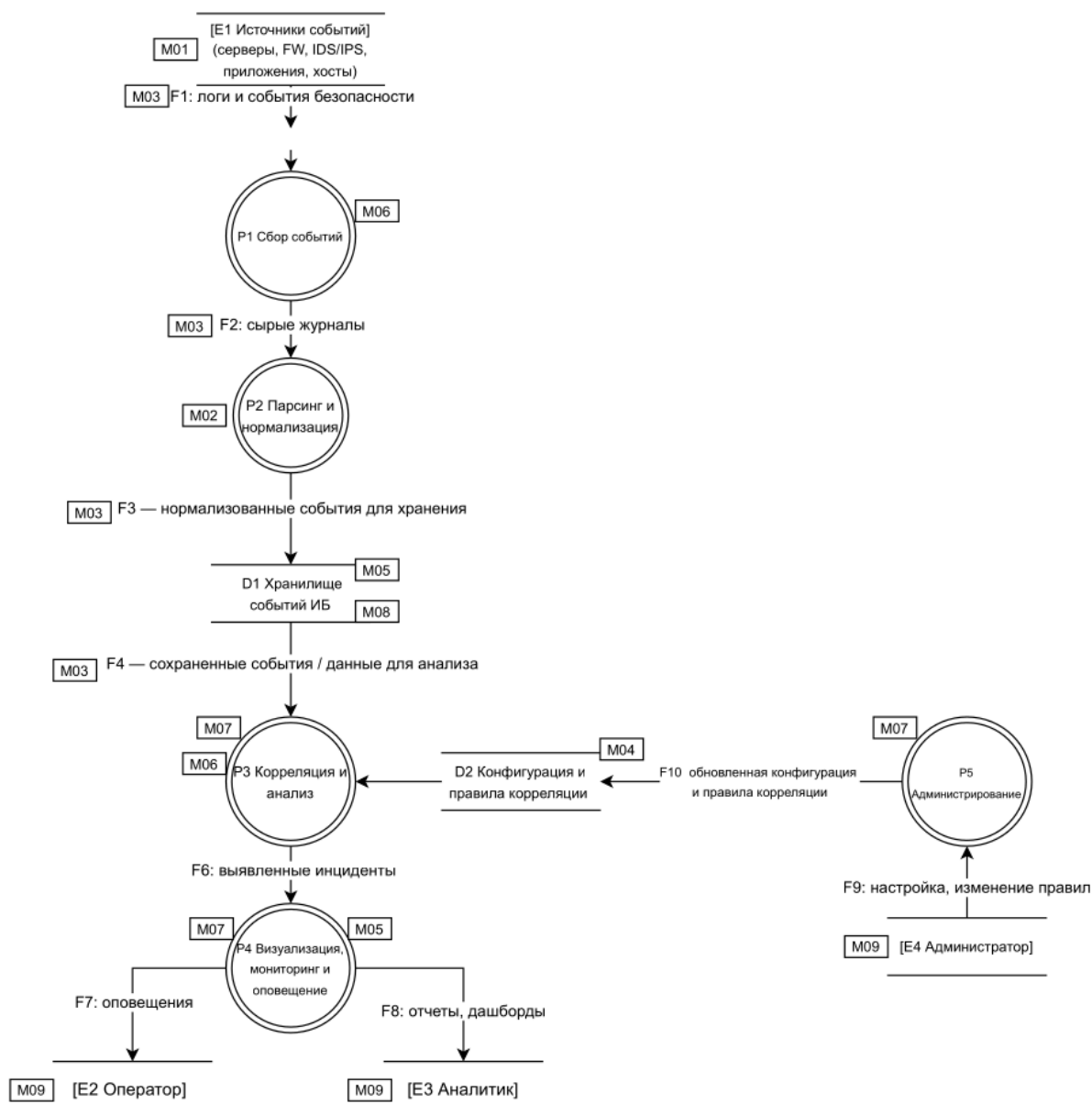


Рисунок 3 – Диаграмма с контрмерами

1.8 Описание контрмер и таблица соответствий «угроза–противодействие»

Для снижения вероятности реализации выявленных угроз и уменьшения возможного ущерба для SIEM-системы необходимо использовать комплекс организационных и технических контрмер. Предлагаемые меры защиты направлены на обеспечение конфиденциальности, целостности и доступности журналов событий, конфигурации системы, правил корреляции, а также процессов анализа, мониторинга и администрирования.

Контрмеры для SIEM-системы должны охватывать все основные этапы обработки информации: поступление событий от доверенных источников, передачу данных по

защищенным каналам, контроль целостности журналов, защиту хранилищ и конфигурации, ограничение нагрузки на сервисы, защиту приложений и учетных записей пользователей. Комплексное применение указанных мер позволяет снизить риск реализации угроз, выявленных на предыдущих этапах моделирования.

Таблица 7 – Описание контрмер

Идентификатор контрмеры	Наименование контрмеры	Описание
M01	Аутентификация и проверка доверенных источников событий	Обеспечивает подтверждение подлинности источников логов и событий, предотвращает подключение неавторизованных узлов к SIEM-системе
M02	Контроль целостности журналов и валидация входных данных	Позволяет выявлять подделку, изменение и некорректное содержимое журналов, а также проверять входные данные перед обработкой
M03	Защищенные каналы передачи данных	Использование TLS, VPN и других защищенных протоколов для предотвращения перехвата и изменения передаваемой информации
M04	Разграничение доступа к конфигурации и правилам корреляции	Ограничивает изменение параметров SIEM-системы и правил корреляции только уполномоченными пользователями
M05	Разграничение доступа к логам, отчетам и дашбордам	Предоставляет доступ к журналам событий и аналитическим материалам только авторизованным пользователям
M06	Ограничение нагрузки и защита от DoS-атак	Включает фильтрацию трафика, ограничение числа запросов,

		балансировку нагрузки и иные меры обеспечения доступности
M07	Защита приложений и сервисов SIEM-системы	Предусматривает использование средств защиты приложений, регулярное обновление ПО, устранение уязвимостей и контроль безопасности сервисов
M08	Архивация, ротация и резервирование журналов	Предотвращает переполнение хранилища событий, обеспечивает сохранность логов и возможность их восстановления
M09	Обучение персонала, многофакторная аутентификация и контроль учетных записей	Направлена на снижение риска социальной инженерии, компрометации учетных данных и несанкционированного получения привилегий

Таблица 8 – Таблица соответствий «угроза–противодействие»

Идентификатор угрозы	Наименование угрозы	Соответствующие контрмеры
Y01	Подмена источника событий	M01, M03
Y02	Подделка журналов и событий	M01, M02
Y03	Фальсификация данных при передаче по сети	M02, M03
Y04	Несанкционированное изменение записей журналов	M02, M05
Y05	Несанкционированное изменение конфигурации и правил корреляции	M04, M09
Y06	Раскрытие журналов и служебной информации	M03, M05

Y07	Отказ в обслуживании на сетевом уровне	M06
Y08	Отказ в обслуживании на уровне приложений	M06, M07
Y09	Переполнение журналов	M08
Y10	Социальная инженерия и фишинг	M09
Y11	Эксплуатация уязвимостей приложений и сервисов	M07, M09

Как видно из таблицы соответствий, для каждой выявленной угрозы определены одна или несколько контрмер, позволяющих снизить вероятность ее реализации либо уменьшить возможные последствия. Наиболее важными для SIEM-системы являются меры, связанные с проверкой источников событий, контролем целостности журналов, защитой каналов передачи данных, разграничением доступа к конфигурации и логам, обеспечением устойчивости сервисов к отказам, а также защитой учетных записей пользователей.

Комплексное применение указанных контрмер позволяет повысить устойчивость SIEM-системы к внешним и внутренним воздействиям, обеспечить надежность процессов сбора, хранения и анализа событий информационной безопасности, а также снизить риски нарушения конфиденциальности, целостности и доступности обрабатываемой информации.

ЗАКЛЮЧЕНИЕ

В ходе выполнения лабораторной работы была построена модель угроз для SIEM-системы. В рамках работы было выполнено теоретическое неформальное описание системы, определены основные субъекты, объекты, активы и процессы, связанные со сбором, хранением, обработкой и анализом событий информационной безопасности.

На основе анализа архитектуры SIEM-системы была построена диаграмма потоков данных, отражающая движение информации между источниками событий, подсистемами сбора и нормализации, хранилищем событий ИБ, модулем корреляции и анализа, подсистемой визуализации и оповещения, а также компонентами администрирования. Это позволило выделить основные точки, в которых могут реализовываться угрозы безопасности.

С использованием методологии STRIDE были выявлены актуальные для SIEM-системы угрозы, включая подмену источников событий, фальсификацию журналов и данных при передаче, раскрытие служебной информации, отказ в обслуживании, переполнение хранилища событий, а также угрозы, связанные с социальной инженерией и эксплуатацией уязвимостей приложений и сервисов. Для наглядного представления результатов были построены диаграмма с угрозами и перечень выявленных угроз.

На следующем этапе были определены контрмеры, направленные на снижение вероятности реализации выявленных угроз и уменьшение возможного ущерба. Была построена диаграмма с контрмерами, а также составлена таблица соответствий «угроза–противодействие», показывающая взаимосвязь между потенциальными угрозами и предлагаемыми мерами защиты.

Таким образом, цель лабораторной работы была достигнута. Построенная модель угроз позволяет комплексно оценить риски безопасности SIEM-системы и может служить основой для дальнейшего совершенствования механизмов защиты, повышения устойчивости системы к внешним и внутренним воздействиям и обеспечения надежного функционирования процессов мониторинга информационной безопасности.